

Security+ 2.4 · Physical Attacks

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.4 — Physical Attacks (4:04) · [vídeo original ↗](#) · [YouTube ↗](#)

Ataque físico: brute force física (cortar cadeado, força porta); RFID cloning (clonar badge NFC); environmental (pular cerca, furar parede). Defesa: mantrap/vestibular control, badge + PIN (2 fatores físico), câmeras, alarmes, monitorar log RFID com alarme de horário incomum.

Highlights que a prova cobra

- RFID cloning com um device de \$500 copia um badge (proximity)
- Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes

Dicas de prova

- 'clones an access badge' = RFID cloning

Cenário clássico: Cenário: 'invasor copia o badge de funcionário e entra na sala de servidor' = RFID cloning.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Um atacante usa RFID para clonar crachás de funcionários e acessar áreas restritas. Que tipo de ataque físico é esse?

- A) Tailgating
- B) Shoulder surfing
- C) Clonagem de credenciais
- D) Dumpster diving

2. Sistema-isca que finge ser vulnerável pra atrair e estudar atacantes:

- A)** Honeypot
- B)** DMZ
- C)** Bastion host
- D)** Jump box

3. Cenário corporativo (Physical Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'RFID cloning com um device de \$500 copia um badge (proximity)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: RFID cloning com um device de \$500 copia um badge (proximity)...

4. Cenário corporativo (Physical Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes...

5. Cenário corporativo (Physical Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'clones an access badge' = RFID cloning'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'clones an access badge' = RFID cloning...

6. Cenário corporativo (Physical Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'invasor copia o badge de funcionário e entra na sala de servidor' = RFID cloning.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário: 'invasor copia o badge de funcionário e entra na sala de servidor'...

7. Cenário corporativo (Physical Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'RFID cloning com um device de \$500 copia um badge (proximity)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: RFID cloning com um device de \$500 copia um badge (proximity)...

8. Cenário corporativo (Physical Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Physical Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'clones an access badge' = RFID cloning'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'clones an access badge' = RFID cloning...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Physical Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'invasor copia o badge de funcionário e entra na sala de servidor' = RFID cloning.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'invasor copia o badge de funcionário e entra na sala de servidor'...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) C — Clonagem de credenciais.** Clonagem de credenciais RFIDs permite criar cópias não autorizadas de crachás/cartões de acesso, permitindo entrada física não autorizada em instalações.
- 2) A — Honeypot.** Honeypot é armadilha: parece alvo real, serve pra detectar/estudar o atacante. Honeynet = rede de honeypots.
- 3) D — Implementar a solução correspondente: RFID cloning com um device de \$500 copia u.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Physical Attacks): RFID cloning com um device de \$500 copia um badge (proximity). As demais alternativas configuram violações graves de
- 4) D — Implementar a solução correspondente: Defesa física: mantrap, badge com PIN (2-f.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Physical Attacks): Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes. As demais alternativas configuram violações grave
- 5) D — Implementar a solução correspondente: 'clones an access badge' = RFID cloning....** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Physical Attacks): 'clones an access badge' = RFID cloning. As demais alternativas configuram violações graves de conformidade ou falha
- 6) D — Implementar a solução correspondente: Cenário: 'invasor copia o badge de funcion.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Physical Attacks): Cenário: 'invasor copia o badge de funcionário e entra na sala de servidor' = RFID cloning.. As demais alternativas
- 7) D — Implementar a solução correspondente: RFID cloning com um device de \$500 copia u.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Physical Attacks): RFID cloning com um device de \$500 copia um badge (proximity). As demais alternativas configuram violações graves de
- 8) C — Implementar a solução correspondente: Defesa física: mantrap, badge com PIN (2-f.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Physical Attacks): Defesa física: mantrap, badge com PIN (2-factor), câmeras+alarmes. As demais alternativas configuram violações grave
- 9) C — Implementar a solução correspondente: 'clones an access badge' = RFID cloning....** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Physical Attacks): 'clones an access badge' = RFID cloning. As demais alternativas configuram violações graves de conformidade ou falha
- 10) A — Implementar a solução correspondente: Cenário: 'invasor copia o badge de funcion.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Physical Attacks): Cenário: 'invasor copia o badge de funcionário e entra na sala de servidor' = RFID cloning.. As demais alternativas

